Mitigating Liability in Corporate AI Use: A Policy Framework for Reducing Legal and Security Risk

Cora Snyder

Department of Computer Science, The College of William & Mary

CSCI 520: Cybersecurity & The Law

Dr. Chris Shenefiel

December 7, 2025

As more companies and employees incorporate AI usage into their workflows, the need for AI-specific corporate policies grows. The use of AI, if unregulated, opens both the company and individual employees to legal, privacy, and security risks: if data is mishandled in the process of using AI, or if the AI vendor itself is breached, the company may be held legally liable. State cybersecurity insurance laws, the Federal Trade Commission (FTC), and the National Institute of Standards and Technology (NIST), among others, provide a legal framework for the company regulation of AI usage. This paper proposes an internal AI governance policy designed to reduce company and individual liability.

Company Profile Assumption

This proposal assumes a mid-size company that handles non-medical, non-financial personally identifiable information (PII). In addition, the company is non-publicly traded, operating in the U.S., and based in a state with cybersecurity insurance laws. Assuming that the company engages in trade, commerce, transportation, or communication across state lines, it also fulfills the definition of interstate commerce as outlined by Title 15, Section 78c(a)(17) of the U.S. Code (Securities Exchange Act of 1934, 2022). This company currently lacks a centralized AI usage policy, although non-AI focused cybersecurity infrastructure—such as third party risk management and an information security program—do exist. The lack of AI usage policy when dealing with PII poses a critical legal risk to the company in the form of vendor breaches, federal and state liability, and legal standing.

Legal and Regulatory Environment for Corporate Liability

Multiple legal and regulatory frameworks apply to the corporate usage of AI. The term *personally identifiable information*, or PII, refers to “any information about an individual

maintained by an agency, including (1) any information that can be used to distinguish or trace an individual's identity, such as name, Social Security number, date and place of birth, mother's maiden name, or biometric records; and (2) any other information that is linked or linkable to an individual, such as medical, educational, financial, and employment information" (GAO, 2008). Under this definition, any company collected data, or internal employee data, which fits these descriptions constitutes PII and must be treated as sensitive data.

Any entity which engages in interstate commerce falls under the jurisdiction of the Federal Trade Commission, including the assumed company. Under the Federal Trade Commission Act, the FTC has the power to prosecute companies which employ "unfair or deceptive acts or practices" (15 USC § 45(a)(1), 2022). Federal Trade Commission v. Wyndham Worldwide Corp., 799 F.3d 236 (3d Cir. 2015), extended this power to include the prosecution of companies which claimed data security without implementing reasonable processes to secure data. In addition to being responsible for their own security, companies can also be held liable for a lack of security on the part of their third party vendors. In 2023, the FTC filed a complaint against Ring LLC for allowing third party vendors access to sensitive data (In re Ring LLC, 2023). Through the FTC's act of guidance by enforcement, the case solidified a company's responsibility to vet and secure their vendors.

The FTC uses the term "reasonable" as a baseline for security standards: "a company's data security measures must be reasonable in light of the volume and sensitivity of information the company holds, the size and complexity of the company's operations, the cost of the tools that are available to address vulnerabilities, and other factors" (Arias, 2016). The FTC heavily encourages the use of the NIST framework to ensure reasonable security measures are being

taken. Companies should also adhere to state cybersecurity insurance law requirements, if applicable.

Risk Assessment and Identification of Organizational Needs

Current Gaps in Corporate Policy

An internal AI governance policy both provides a baseline standard for AI usage, in alignment with the existing cybersecurity program, as well as addresses specific gaps in the current policy. Without an AI-specific Acceptable Use Policy or employee training, staff lack guidance on several key issues: which AI tools are prohibited, whether certain categories of PII may be used, what level of redaction is required, and how to handle sensitive data in practice. AI also needs to be formally incorporated into existing third-party vendor rules, including documentation requirements, contracts, and security reviews. Without monitoring AI usage and related incidents, the company cannot detect risks promptly, resulting in delayed responses to downstream breaches. Existing documentation should be expanded to explain how, why, when, and where AI may be used, and all usage must be logged to create an audit trail. Documentation and audit logs are a key tool in reducing legal liability.

Liability

Article III of the U.S. Constitution requires that in federal cases, such as those brought by the FTC against corporations, the plaintiff shows standing. In the case of Lujan v Defenders of Wildlife (1992), the supreme court established three key elements of legal standing: injury in fact, redressability, and traceability. Traceability is critical to reducing company liability for two reasons. Firstly, if a data breach is traced back to company AI usage, then the company can be held liable. Secondly, if the company lacks the necessary documentation to trace the breach to

another entity or corporation, the risk of suits against the company meeting the legal requirements for standing increases.

Finally, cybersecurity insurance, if the company has it, often does not cover certain situations such as reckless practices, failure to maintain security standards, and sometimes third party vendor breaches. This is one more way in which the company would potentially face legal liability. To safeguard against potential suits and liability, the company should adhere to the following reasonable security measures.

Proposed Corporate Cybersecurity Policy

Vendor & Third-Party Risk Controls

Implementation Strategy

The company should regard AI as a third party tool, entering into a legal agreement regarding the terms of service, and implementing cybersecurity measures appropriate for any other third party service provider. AI vendor security practices should be implemented in three phases.

Before Employing AI. The company will research and select an AI vendor from which they will obtain a business account. Free AI services will not be used for any company purpose. The chosen vendor will undergo appropriate security screenings, risk assessments, and background checks if necessary. This includes a thorough review of terms of service and, if applicable, third party vendors employed by the AI service provider. Any identified gaps in third party security will be addressed in the contract where possible and accepted or mitigated where not.

While Using An AI Agent. The company will perform regular audits of AI vendor security and compliance. This includes requesting audit logs, monitoring third party security

incidents, performing risk assessments, and including the third party vendor in enterprise data security and risk management activities.

After Cessation Of Services. The company will ensure that data retained by the AI vendor is destroyed. In addition, the company will continue to include the vendor in risk management and assessment activities until such time as the vendor is shown to pose insignificant security risk.

Alignment with known frameworks

The above policy points align with the NIST Cybersecurity Framework. Maintaining a list of permitted AI vendors fulfills the GV.SC-04 requirement that vendors are known (National Institute of Standards and Technology, 2024). The need for planning, due diligence, and rectification of cybersecurity needs prior to entering a formal contract with a third party vendor is laid out in GV.SC-05 and GV.SC-06 (NIST, 2024). GV.SC-08, GV.SC-09, and GV.SC-02 mandates that vendors are included in enterprise security programs, documentation, and compliance checks (NIST, 2024). GV.SC-10 recommends that supply chain risk management does not cease with the termination of a partnership.

Legal & Risk-Reduction Rationale

By limiting AI usage to vendors with whom the company has a formal contract, and prohibiting the use of unpaid accounts or free trials the company accomplishes two goals: it maintains clarity about which AI tools are authorized, and it secures the contractual protections associated with a business account rather than a consumer or free tier. For example, as of 2024, OpenAI retains the right to use any data collected from a free account, but requires customer consent to data usage for business and enterprise accounts (OpenAI, 2024).

The information-gathering requirements listed above allow the company to maintain thorough documentation of known risks. This approach allows the company to avoid unnecessary security risks where possible or address new risks with little delay. Compliance with NIST guidelines also fulfills the FTC's definition of reasonable security measures, reducing risk of prosecution under the Federal Trade Commission Act.

Governance & Roles

Implementation Strategy

Within the preexisting cybersecurity program, an additional team or board will be formed and designated in charge of AI usage. The team will assess and vet potential AI vendors before contract execution, maintain comprehensive security documentation and audit logs, and conduct ongoing risk assessments. In collaboration with human resources, the team will integrate AI security into employee training programs while monitoring personnel AI usage. Finally, the team will manage all AI-related incident response activities.

Alignment with known frameworks

The above policies align with the NIST Cybersecurity Framework guideline GV.RR regarding roles, responsibilities, and authorities. GV.RR instructs companies to designate authorities and assign responsibilities in order to promote accountability and maintain security efforts (NIST, 2024). The establishment of this team would also reinforce the company's fulfillment of DE.CM-03 and GV.OV-03, which relate to organizational risk management assessments and the monitoring of internal potentially adverse events (NIST, 2024). State insurance cybersecurity law requires a designated person to be responsible for information security program, written information security program, and staying informed regarding emerging relevant threats.

Legal & Risk-Reduction Rationale

The alignment with the NIST standards, and the establishment of accountability for AI-related security, reduces the company's chance of failing the FTC's "reasonable" security standard. The assignment of responsibility, as well as the documentation, provides traceability in the case of a legal suit. The oversight provided by this team also allows for early detection of risky AI use, preventing future incidents which may lead to a breach.

Employee Policies

Implementation Strategy

To ensure minimal risk of data or AI mishandling, employees in all areas of the company will receive training regarding acceptable use of approved AI. Trainings will demonstrate how to distinguish sensitive data, in particular, PII, from general data according to legal definitions. Employees will be warned against inputting sensitive data into AI tools. Trainings will emphasize the importance of excluding or redacting sensitive information in prompts. Employees will also be made aware of the legal and security implications of improper data handling.

Alignment with known frameworks

The above policy aligns with the NIST cybersecurity framework. GV.RR-04 recommends that cybersecurity be included in human resources practices in general, while PR.AT-01 emphasizes the importance of trainings geared towards implementing security knowledge and skills in the performance of general tasks (NIST, 2024). In addition, many state cybersecurity insurance laws often requires employee trainings.

Legal & Risk-Reduction Rationale

Having employees undergo mandatory training regarding acceptable AI use greatly reduces the likelihood of an individual employee unintentionally mishandling data. Compliance

with NIST guidelines fulfills the FTC's definition of reasonable security measures, reducing risk of prosecution under the Federal Trade Commission Act. Compliance with state cybersecurity law regulations reduces the risk of state-level legal consequences.

Incident Response & Breach Notification

Implementation Strategy

The team responsible for AI usage will write an appropriate incident response policy specific to each contracted AI vendor. This documented policy will be informed by regular risk assessments and enterprise risk management exercises. In general, two categories of events would prompt incident response in the context of this policy.

A Contracted AI Vendor was Breached. In the case that a contracted third party AI vendor experiences a breach, regardless of how the breach was discovered, the company will review all logs and documentation related to that vendor for an appropriate time duration based on that vendor's data retention policy. If no instances of sensitive information being given to the vendor are found, and state law notification thresholds are not met, then the company will not publish a breach notification of its own. If instances are discovered, all information regarding the breach and mishandling of sensitive data will be presented to the in-house counsel. If there is substantial reason to believe that the company may be found liable, in-house counsel will hire an external firm through which all proceeding investigations will continue. The counsel will also determine based on the location of the breach and victims, the applicable state and federal breach notification laws.

An Employee Mishandled PII with AI. In the event that an employee self-reports or is discovered mishandling sensitive information, particularly PII, in their AI usage, the team responsible for AI will conduct an investigation into the event. If the employee's actions did not

lead to an immediate data leak, then all evidence and information collected during the investigation will be recorded in the event of a later incident. The retention period for this documentation will be no less than the data retention period of the relevant AI vendor. The cybersecurity team and human resources may collaborate to determine penalties for the employee. If the employee's actions do lead to an immediate security breach or data leak, the incident response protocol will be implemented and legal counsel sought.

Alignment with known frameworks

The above policy ensures alignment with state notification laws as well as the NIST Cybersecurity Framework. GV.RM-04 mandates that risk response directions are established and communicated, as would be accomplished by the documentation of an AI-usage data incident response plan (NIST, 2024). The activities which would inform that response plan, which would be included in the overall enterprise risk management process, fulfill GV.RM-03 (NIST, 2024).

Legal & Risk-Reduction Rationale

Alignment with state laws and the NIST CSF decreases the risk of state or federal legal prosecution. In the case that the company may be liable, hiring an external legal firm to then oversee the investigation increases the chance of the resulting reports, logs, etc, being protected under the Work Product Doctrine Rule (Fed. R. Civ. P. 26(b)(3), 2025). That documentation would also allow the company to defend themselves or increase traceability to another entity.

Limitations & Future Considerations

The use and capabilities of AI continue to evolve rapidly. New legislation and regulations emerge in the wake of security breaches and court cases. With major legal developments, cybersecurity policies must be reviewed and adapted to meet the needs of the company as well as

the requirements of the law. In addition, this proposal highlights the most critical elements of an AI governance policy, but is not exhaustive.

Conclusion

To reduce the risk of legal liability, companies should adhere to the guidelines laid out by state laws, industry standards such as NIST CSF, and federal regulations. In order to meet the requirement of reasonable security measures, a company handling PII and using AI must implement new third party vendor, governance, employee, incident response, and security control policies. Together, these policies protect the company from legal liability and provide a secure standard for AI usage.

REFERENCES

Arias, A. (2016, August 31). *The NIST Cybersecurity Framework and the FTC*. Federal Trade Commission. https://www.ftc.gov/business-guidance/blog/2016/08/nist-cybersecurity-framework-ftc#:~:text=The%20Federal%20Trade%20Commission%20(FTC)%20and%20the,Protect%20*%20Detect%20*%20Respond%20*%20Recover .

Federal Rule of Civil Procedure 26(b)(3) (2025).

Federal Trade Commission Act, 15 U.S.C. § 45(a)(1) (2024).

Federal Trade Commission v. Wyndham Worldwide Corp., 799 F.3d 236 (3d Cir. 2015). https://www.ca3.uscourts.gov/opinarch/143514p.pdf.

Government Accountability Office. (2008, April 19). *GAO-08-536 - Privacy: Alternatives Exist for Enhancing Protection of Personally Identifiable Information*. U.S. Government Printing Office. https://www.govinfo.gov/app/details/GAOREPORTS-GAO-08-536.

In re Ring LLC, No. C-4796 (F.T.C. June 1, 2023)

Lujan v. Defenders of Wildlife, 504 U.S. 555 (1992).

National Institute of Standards and Technology. (2024). *CSF 2.0 implementation examples*. https://www.nist.gov/system/files/documents/2024/02/21/CSF%202.0%20Implementation%20Examples.pdf

OpenAI. (2024). *Terms of service*. https://openai.com/policies/terms-of-service

Securities Exchange Act of 1934, 15 U.S.C. § 78c(a)(17) (2022).